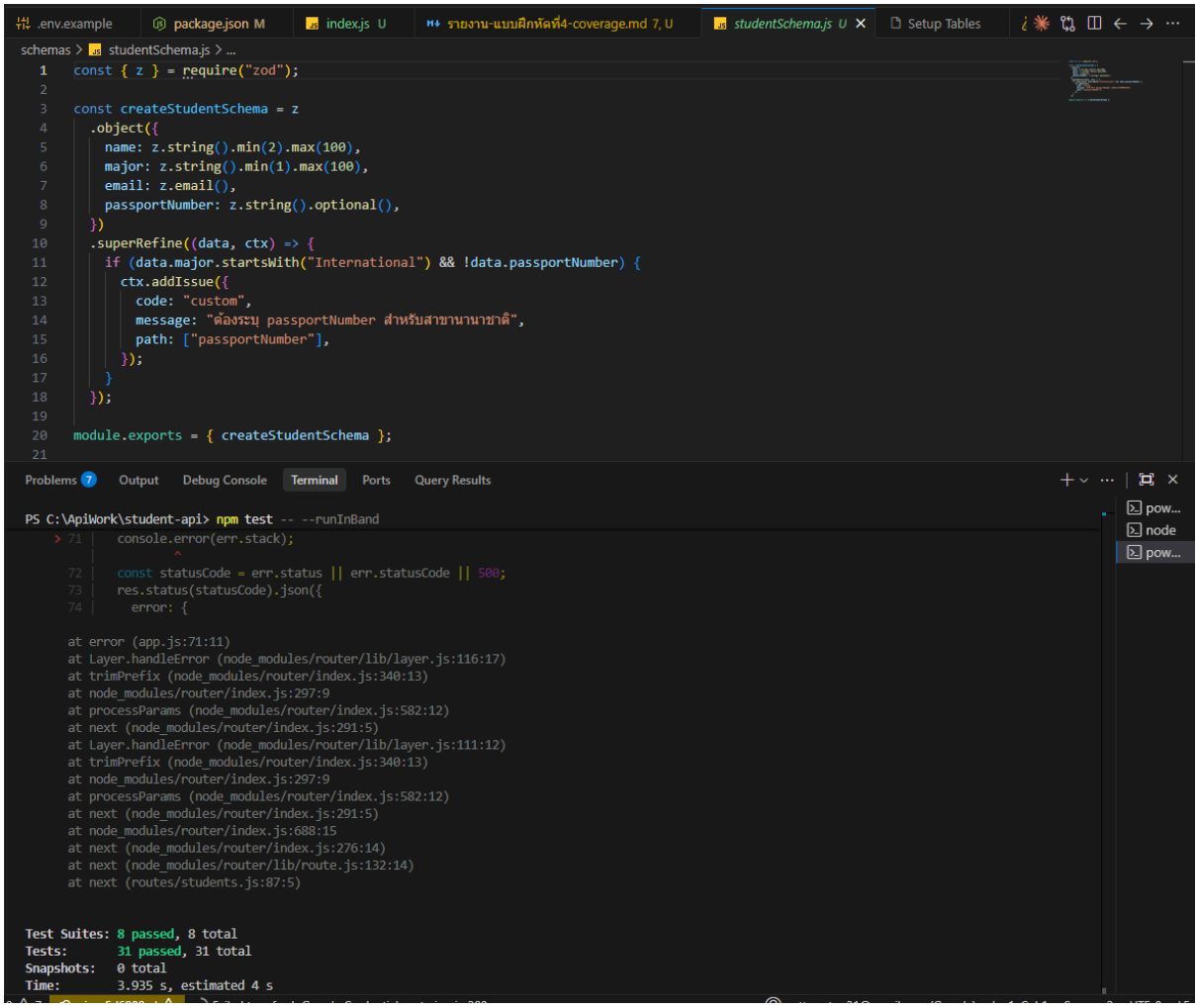
รายงานปฏิบัติการสัปดาห์ที่ 12

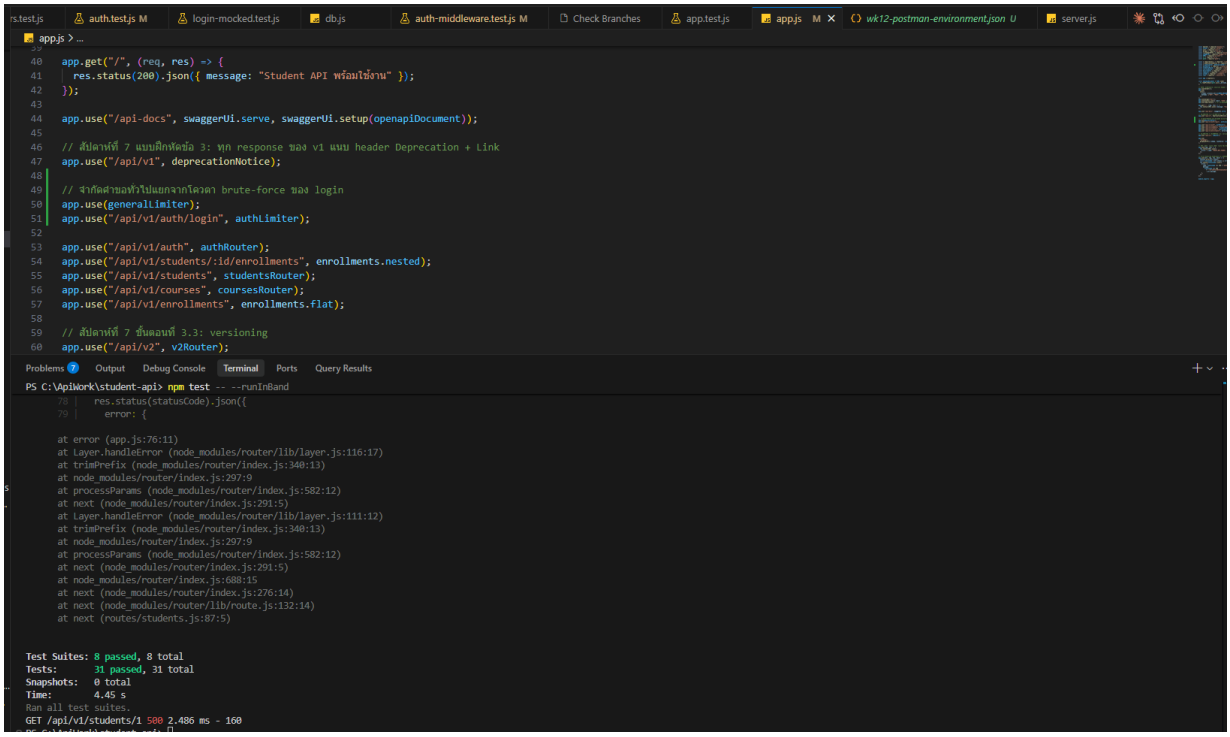
รหัสนิสิต 67160028 ชื่อ ณัฐวุฒิ รู้การนา

จุดตรวจสอบที่ 1 — ชุดทดสอบเดิมและไฟล์ Schema



จุดตรวจสอบที่ 1: รันชุดทดสอบเดิมก่อนเริ่มแก้ไข พบว่าผ่านครบ 8 suites ผ่าน, 31 tests พร้อมเตรียมไฟล์ schemas/studentSchema.js สำหรับตรวจสอบข้อมูลนิสิต

จุดตรวจสอบที่ 2: Validation และ Rate Limiter



```
app.get("/", (req, res) => {
  res.status(200).json({ message: "Student API พร้อมใช้งาน" });
});

app.use("/api-docs", swaggerUi.serve, swaggerUi.setup(openapiDocument));

// สัปดาห์ที่ 7 แบบฝึกหัดข้อ 3: ทุก response ของ v1 แนบ header Deprecation + Link
app.use("/api/v1", deprecationNotice);

// จำกัดคำขอทั่วไปแยกจากโควตา brute-force ของ login
app.use(generalLimiter);
app.use("/api/v1/auth/login", authLimiter);

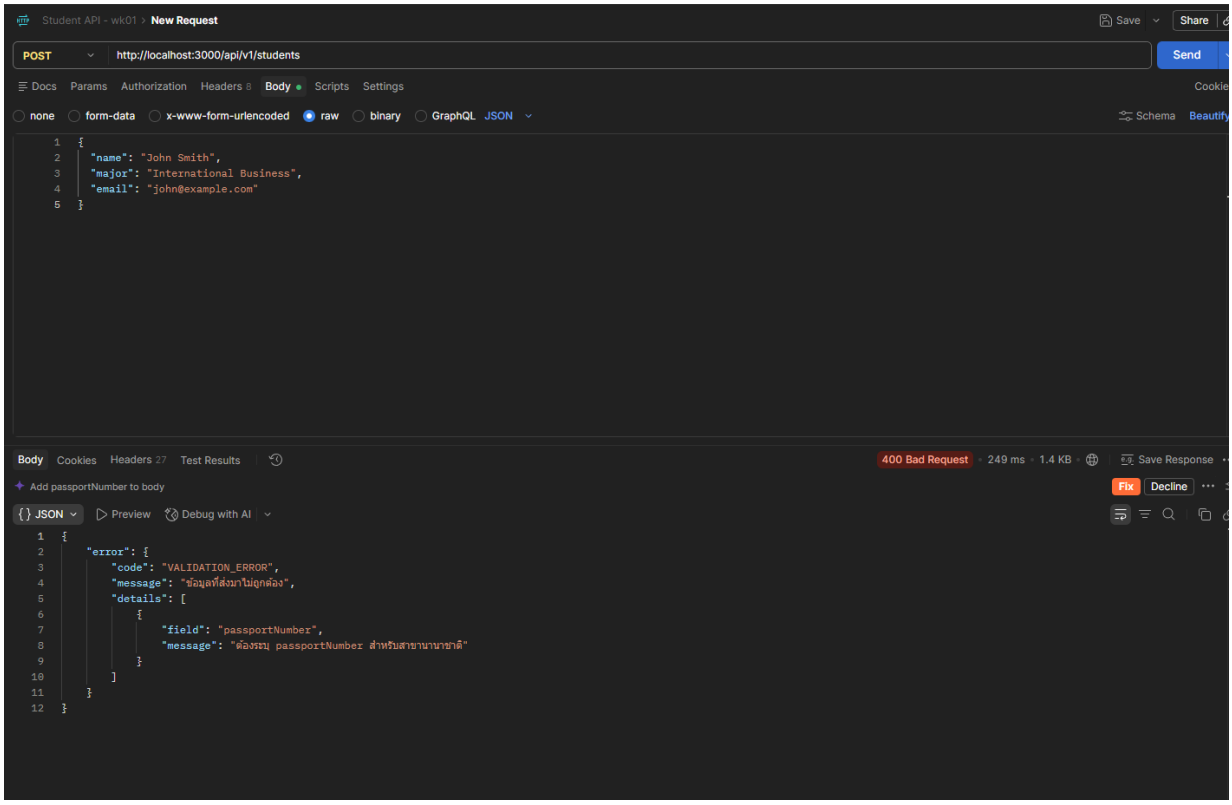
app.use("/api/v1/auth", authRouter);
app.use("/api/v1/students/:id/enrollments", enrollments.nested);
app.use("/api/v1/students", studentsRouter);
app.use("/api/v1/courses", coursesRouter);
app.use("/api/v1/enrollments", enrollments.flat);

// สัปดาห์ที่ 7 ชิ้นตอนที่ 3.3: versioning
app.use("/api/v2", v2Router);
```

```
PS C:\ApiWork\student-api> npm test -- --runInBand
    res.status(statusCode).json({
      error: {

    at error (app.js:76:11)
    at Layer.handleError (node_modules/router/lib/layer.js:116:17)
    at trimPrefix (node_modules/router/index.js:340:13)
    at node_modules/router/index.js:297:9
    at processParams (node_modules/router/index.js:582:12)
    at next (node_modules/router/index.js:291:5)
    at Layer.handleError (node_modules/router/lib/layer.js:111:12)
    at trimPrefix (node_modules/router/index.js:340:13)
    at node_modules/router/index.js:297:9
    at processParams (node_modules/router/index.js:582:12)
    at next (node_modules/router/index.js:291:5)
    at node_modules/router/index.js:688:15
    at next (node_modules/router/index.js:276:14)
    at next (node_modules/router/lib/route.js:132:14)
    at next (routes/students.js:87:5)

Test Suites: 8 passed, 8 total
Tests:       31 passed, 31 total
Snapshots:   0 total
Time:        4.45 s
Ran all test suites.
GET /api/v1/students/1 500 2.486 ms - 160
```

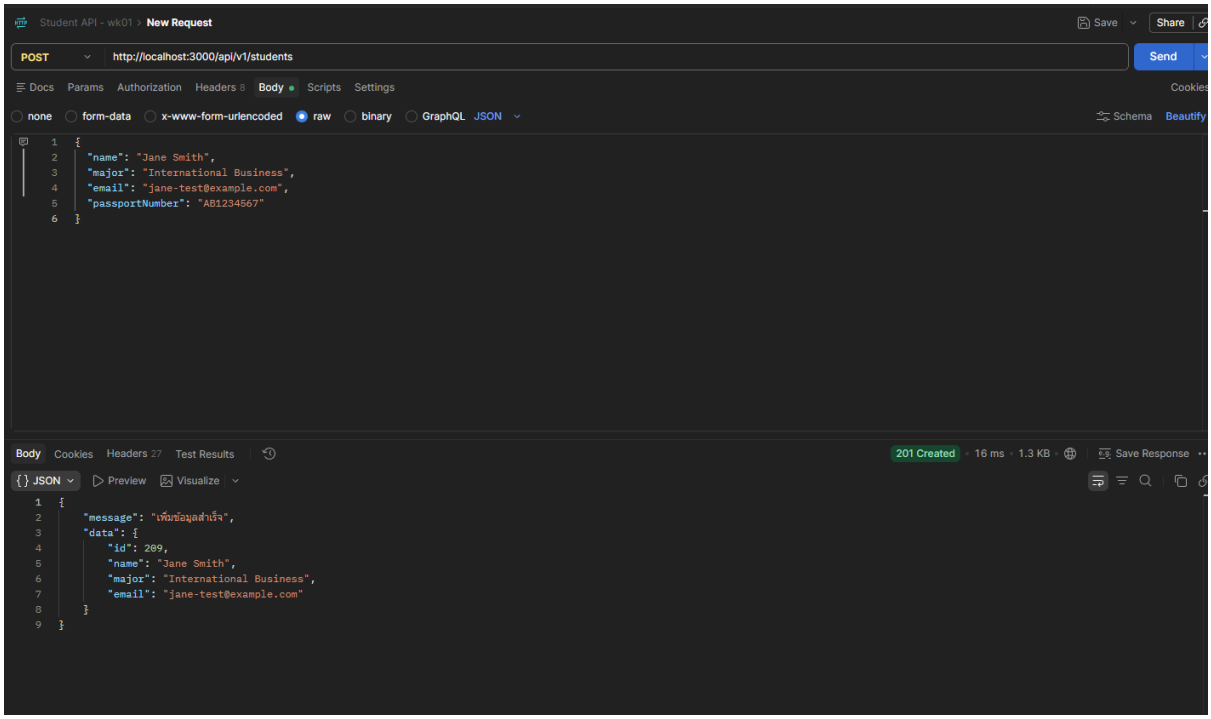


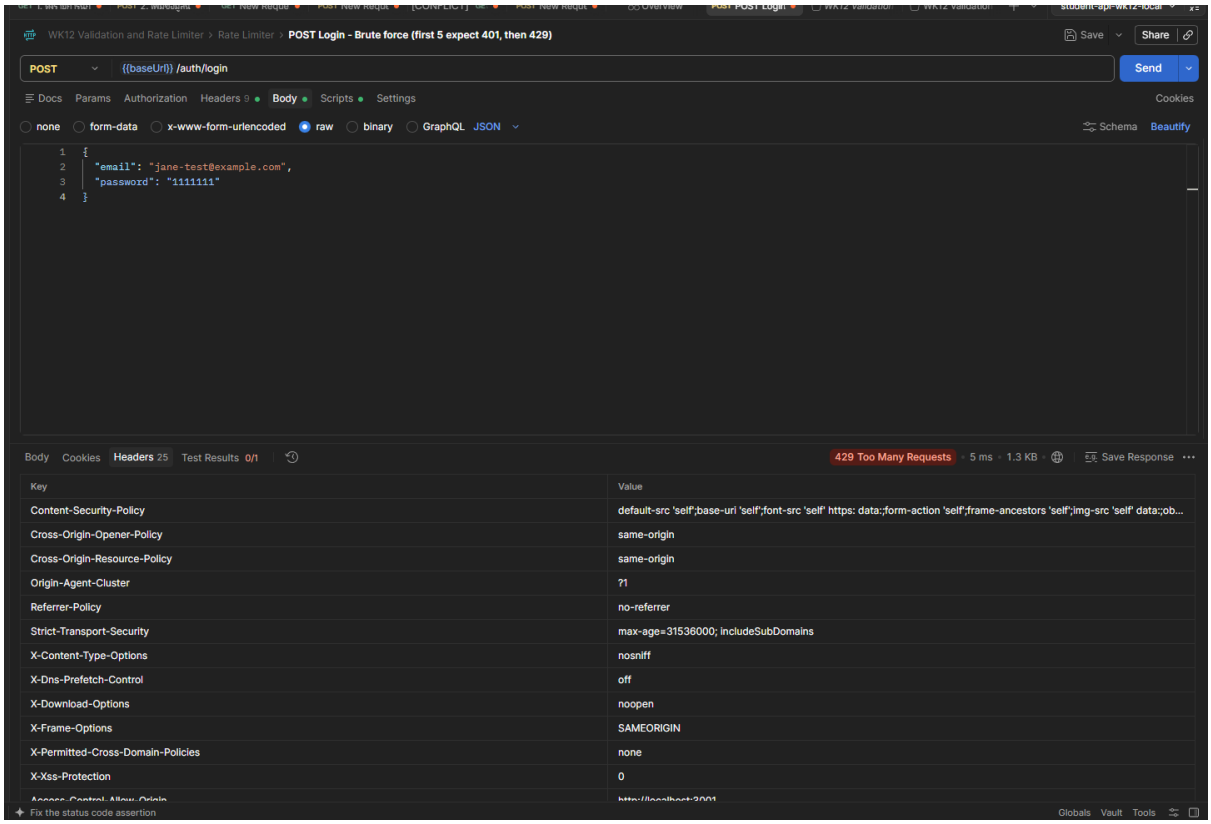
```
POST http://localhost:3000/api/v1/students

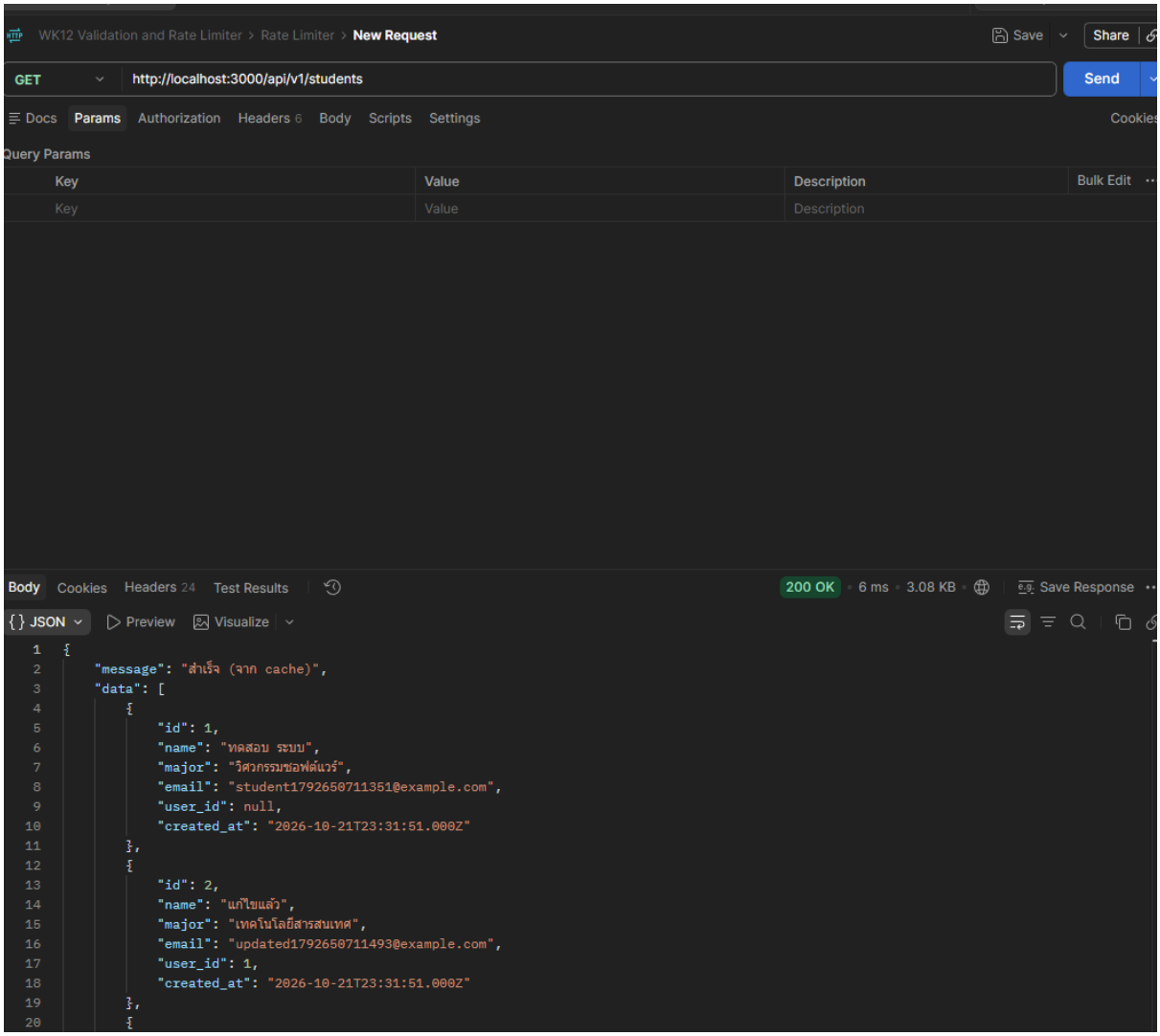
{
  "name": "John Smith",
  "major": "International Business",
  "email": "john@example.com"
}
```

```
400 Bad Request

{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "ข้อมูลที่ส่งมาไม่ถูกต้อง",
    "details": [
      {
        "field": "passportNumber",
        "message": "ต้องระบุ passportNumber สำหรับสายนานาชาติ"
      }
    ]
  }
}
```


Student API - wk01 › New Request
Save
Share
POST
http://localhost:3000/api/v1/students
Send
Docs Params Authorization Headers 8 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
{
"name": "Jane Smith",
"major": "International Business",
"email": "jane-test@example.com",
"passportNumber": "AB1234567"
}
Body Cookies Headers 27 Test Results
201 Created 16 ms 1.3 KB
Save Response
{ } JSON Preview Visualize
{
"message": "เพิ่มข้อมูลสำเร็จ",
"data": {
"id": 209,
"name": "Jane Smith",
"major": "International Business",
"email": "jane-test@example.com"
}
}

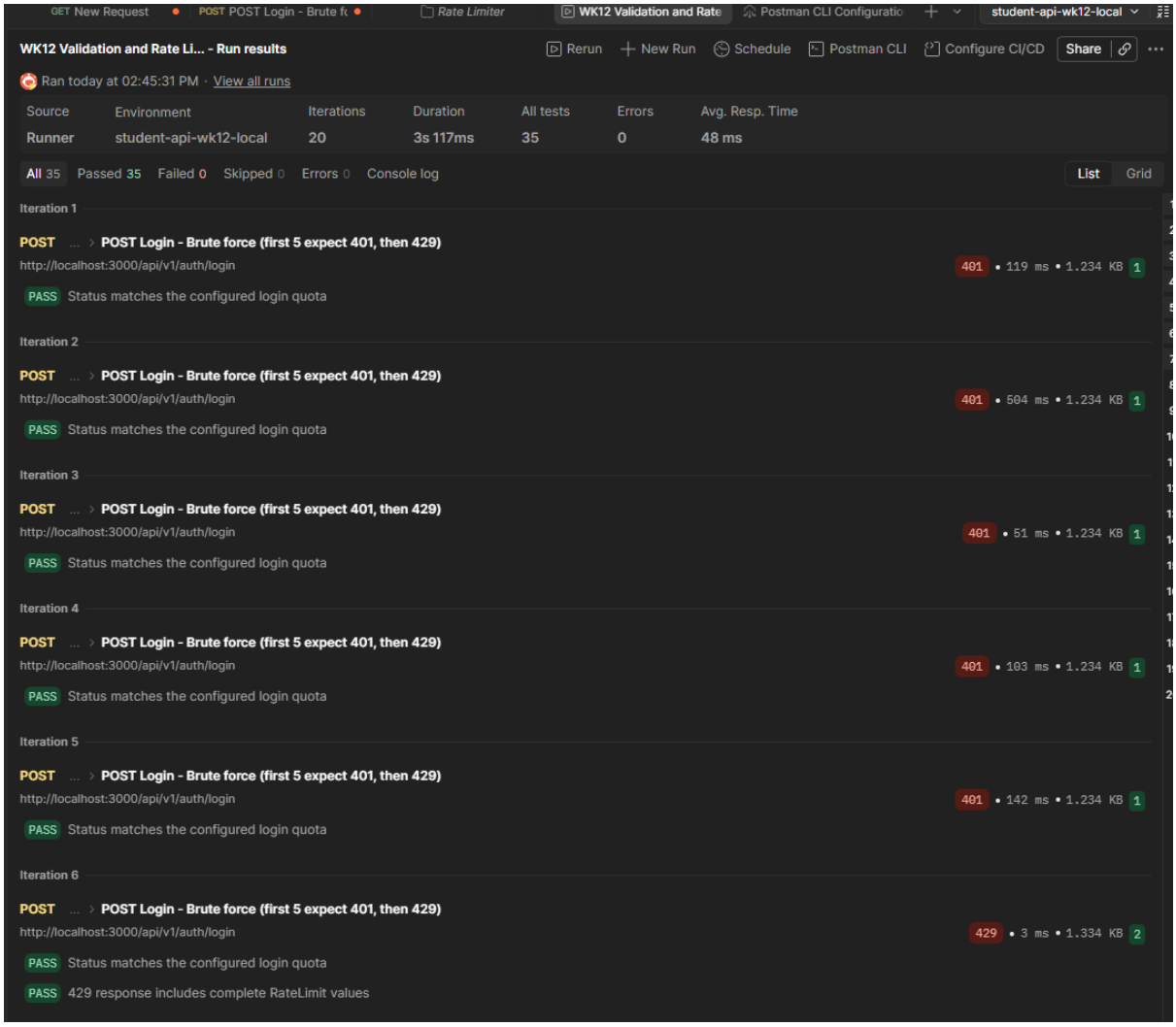

WK12 Validation and Rate Limiter › Rate Limiter › POST Login - Brute force (first 5 expect 401, then 429)
Save
Share
POST
{{baseUrl}} /auth/login
Send
Docs Params Authorization Headers 9 Body Scripts Settings
Cookies
none form-data x-www-form-urlencoded raw binary GraphQL JSON
Schema Beautify
{
"email": "jane-test@example.com",
"password": "1111111"
}
Body Cookies Headers 25 Test Results 0/1
429 Too Many Requests 5 ms 1.3 KB
Save Response
Key
Value
Content-Security-Policy
default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;ob...
Cross-Origin-Opener-Policy
same-origin
Cross-Origin-Resource-Policy
same-origin
Origin-Agent-Cluster
?1
Referrer-Policy
no-referrer
Strict-Transport-Security
max-age=31536000; includeSubDomains
X-Content-Type-Options
nosniff
X-Dns-Prefetch-Control
off
X-Download-Options
noopen
X-Frame-Options
SAMEORIGIN
X-Permitted-Cross-Domain-Policies
none
X-Xss-Protection
0
Fix the status code assertion
Globals Vault Tools

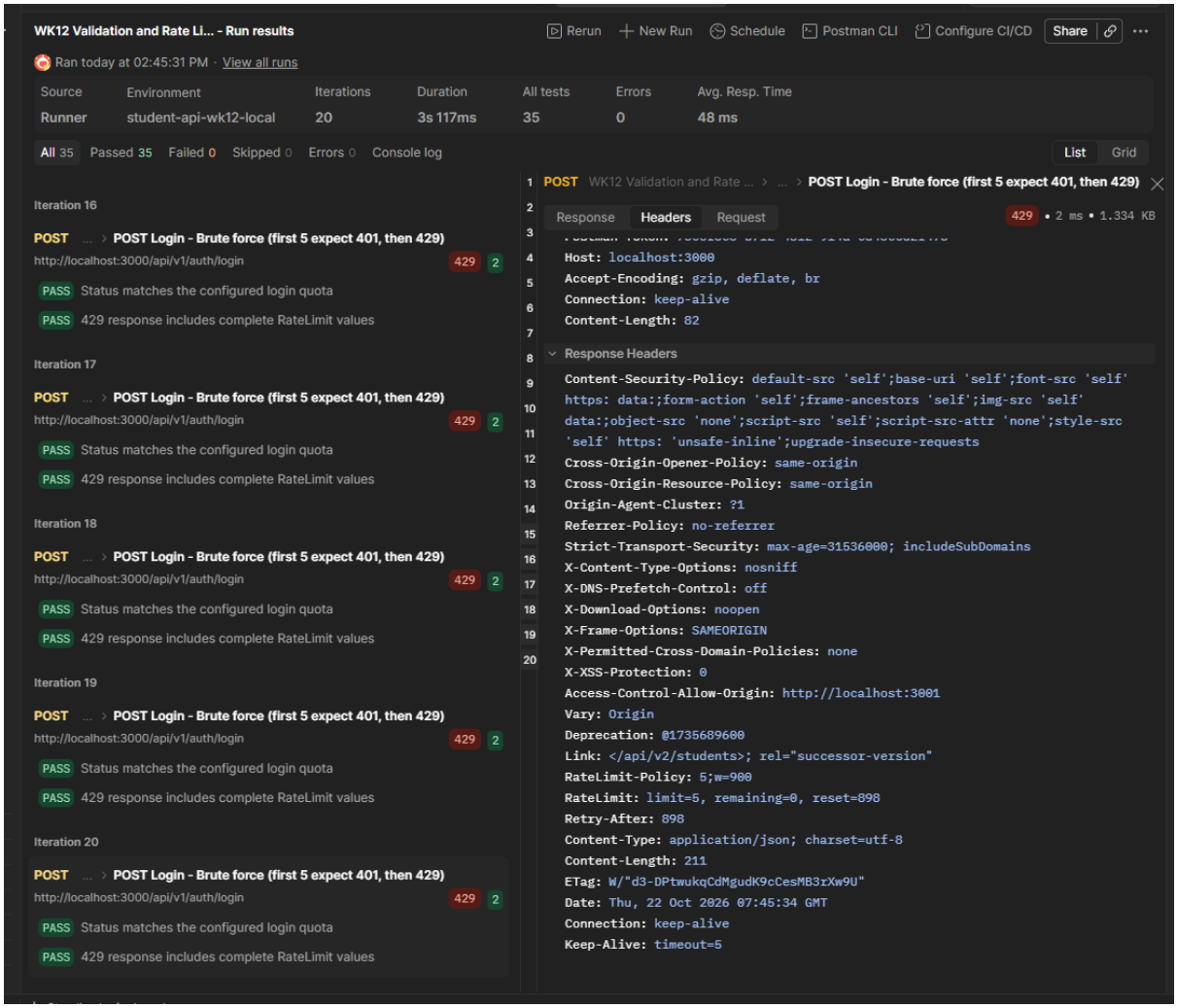


ใช้ Zod ตรวจข้อมูลของ POST /api/v1/students โดยกำหนดว่าเมื่อนิสิตเลือกสาขาที่ขึ้นต้นด้วย International ต้องส่ง passportNumber มาด้วย หากไม่ส่ง ระบบตอบ 400 VALIDATION_ERROR พร้อมระบุ field ที่ผิด หากส่งครบระบบสร้างข้อมูลสำเร็จด้วย 201 Created โดยใช้ passportNumber ตรวจเงื่อนไขเท่านั้น

ตั้ง authLimiter สำหรับ Login และ generalLimiter สำหรับ request ทั่วไปแยกกัน ผลทดลองพบว่าเมื่อ Login ถูกจำกัดด้วย 429 แล้ว GET /api/v1/students ยังตอบ 200 จึงยืนยันว่าโควตาทำงานแยกกัน ชุดทดสอบ Jest/Supertest ผ่านครบ 8 suites, 31 tests

จุดตรวจสอบที่ 3: Brute-force และ RateLimit header





ทดสอบส่งคำขอ login ที่ใช้ข้อมูลไม่ถูกต้องซ้ำ 20 ครั้งผ่าน Postman Runner คำขอช่วงแรกตอบกลับ 401 Unauthorized และหลังเกินโควตา ระบบตอบกลับ 429 Too Many Requests ภาพผลทดสอบแสดง header RateLimit: limit=5, remaining=0, reset=898 หมายถึงกำหนดโควตาไว้ 5 ครั้ง ใช้ครบแล้ว และเหลือเวลาประมาณ 898 วินาทีก่อนเริ่มนับโควตาใหม่